

## Due Care and Due Diligence

### Due Care

- **"Do the right thing."** It means taking reasonable actions to ensure security and compliance, constantly evaluating whether you are following logical and accepted rules. For example, in the healthcare industry, it includes adhering to regulations, standards, and best practices established by peers or authorities.
- It's about **correcting issues immediately**- "Do Correct."
- In essence, due care is when a company does everything it could reasonably do to prevent a security breach, compromise, or disaster and implements the required safeguards or controls.

### Due Diligence

- **"Do Detect."** It goes beyond just fixing issues-it involves actively monitoring, reviewing logs, and striving for continuous improvement.
- It takes longer than due care as it focuses on **investigating the root cause** of an incident, breach, or event to understand why it occurred and ensure it doesn't happen again.
- For example, not just implementing a firewall but also monitoring its logs, reviewing its performance, and ensuring the implemented controls are effective.